PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	The mobile app was created to connect sellers and shoppers. The app will allow communication via direct messages between sellers and shoppers. Transactions will be processed through the app, with several payment options available. Data protection regulations such as GDPR and credit card security standards such as PCI DSS need to be considered.
II. Define the technical scope	Application Programming Interfaces (APIs) will be commonly used as there will be a lot of interactions between customers and sellers. Public Key Infrastructure (PKI) will be used throughout the app to encrypt sensitive data, such as customer and credit card information. Another way sensitive information, such as passwords, will be protected is through hashing using SHA-256. SQL will be used to store information about the sneakers for sale, as well as the sellers listing them.
III. Decompose application	Sample data flow diagram
IV. Threat analysis	A malicious hacker could gain access to sensitive information, such as credit card details. A disgruntled employee could misuse their access to obtain or disclose sensitive customer information.
V. Vulnerability analysis	There could be weaknesses in the SQL database that may allow for SQL injection attacks. Broken access controls could allow buyers or sellers to access information or functionality they should not have permission to access.
VI. Attack modeling	Sample attack tree diagram

VII. Risk analysis and impact	1. Prepared statements can be used to reduce the likelihood of SQL injection attacks. 2. MFA and strong password policies can be used to reduce the likelihood of brute-force attacks. 3. Hashing and salting can be used to protect stored passwords if a database is compromised. 4. CAPTCHA can be used to help ensure users are human and not malicious bots.